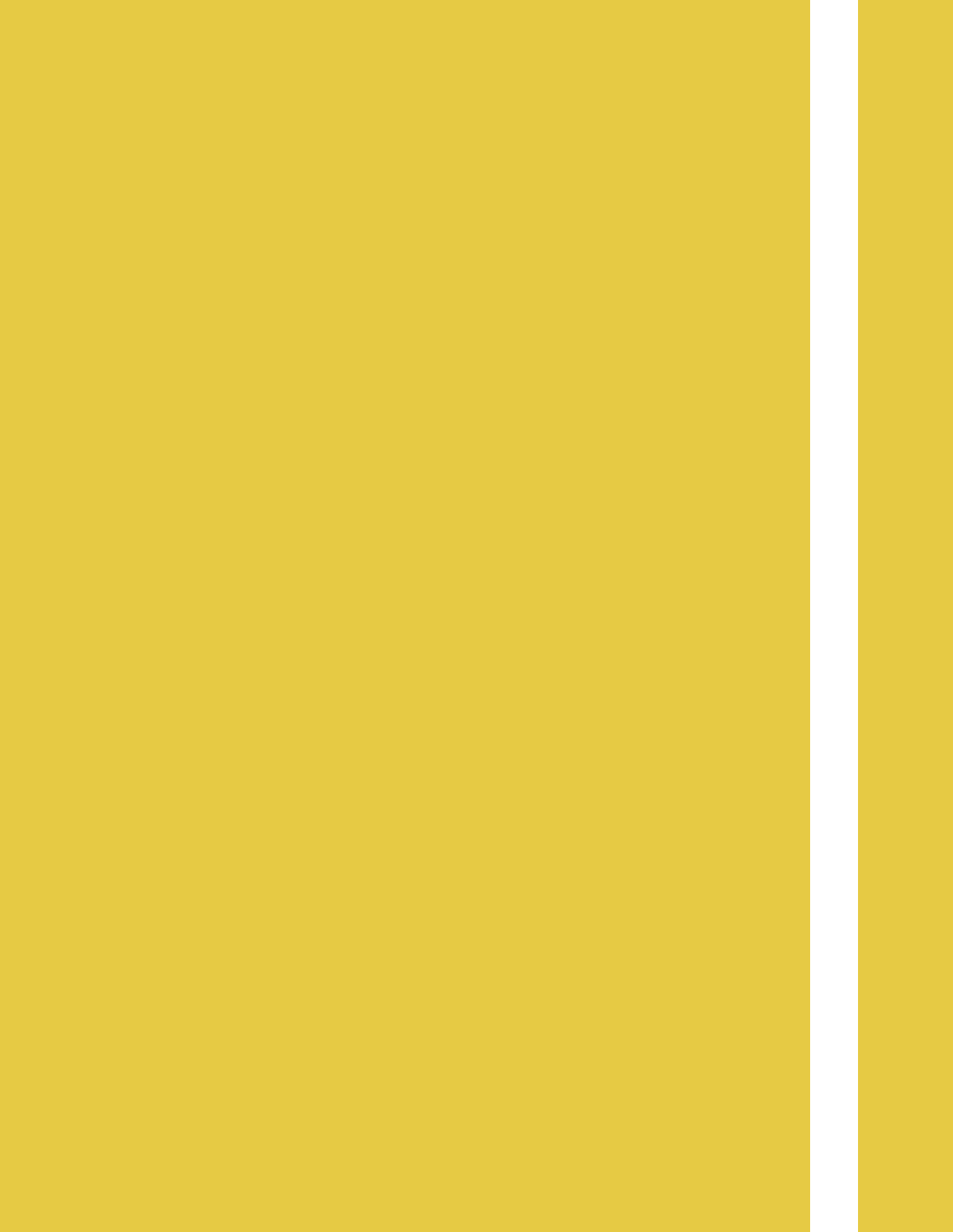




1.1 Security Controls:

Technical Controls:

- Controls implemented using systems
- Operating system controls
- Firewalls, anti-virus,

Managerial Controls:

- Administrative controls associated with security design and implementation
- Security Policies, Standard Operating Procedures

Operational Controls:

- Controls implemented by people rather than systems
- Security guards, awareness programs.

Physical Controls:

- Limit physical access
- Guard shack
- Fences, locks
- Badge readers.

Control Types:

Preventive:

• Block Access to a resource

• "You shall not pass!"

Prevent Access:

• Firewall Rules

• Follow Security Policy

• Guard Shack Checks all IDs

• Enforces door locks

Technical	Preventive	
	Firewall	
Managerial	On-boarding Policy	
Operational	Guard Shack	
Physical	Door Lock	

Deterrent:

• Discourages an intrusion attempt

• Does not directly prevent access

Make an attacker think twice

• Attention Splash Screens

• Threat or demotion

• Front Reception desk

• Pooled Warning Signs

Technical	Preventive	Deterrent	
	Firewall	Splash Screens	
Managerial	On-boarding Policy	Threat or demotion / dismissal	
Operational	Guard Shack	Front Reception Desk	
Physical	Door Lock	Warning Signs	

Detective

• Identify and log on intrusion attempt

• May not prevent access

Find the Issue:

• Collect + Review system logs

• Review login attempts

• Regularly Patrol the Property

• Enable Motion Detectors

Technical	Preventive	Deterrent	Detective
	Firewall	Splash Screens	System Logs
Managerial	On-boarding Policy	Threat of demotion / dismissal	Review login Attempts
Operational	Guest Shack	Front Reception Desk	Patrol Property
Physical	Door Lock	Warning Signs	Motion Detectors

Corrective:

• Apply a control after an event has been detected

• Reverse the impact of an event

• Continue operating with minimal downtime

Correct the Problem: (Assume Ransomware)

• Restore from backups can mitigate a ransomware infection

• Create Policies for reporting security issues

• Contact Law enforcement to manage criminal activity

• Use a fire extinguisher

Technical	Preventive	Deterrent	Detective	Corrective
	Firewall	Splash Screens	System Logs	Backup & Recovery
Managerial	On-boarding Policy	Threat of demotion / dismissal	Review login Attempts	Policies for reporting issues
Operational	Guest Shack	Front Reception Desk	Patrol Property	Contact Authorities
Physical	Door Lock	Warning Signs	Motion Detectors	Fire Extinguisher

Compensating:

- Control Using Other Means

- Existing controls aren't sufficient

- May be Temporary

Prevent the Exploitation of a Weakness

- Firewall blocks a specific application instead of Patching the app

- Implement a Separation of duties

- Require simultaneous good duties

- Generator used after Power outage:

	Preventive	Deterrent	Detective	Corrective	Compensating	
Technical	Firewall	Splash Screens	System Logs	Backup & Recovery	Block instead of Patch	
Managerial	On-boarding Policy	Threat of demotion / dismissal	Review login Attempts	Policies for reporting issue	Separation of Duties	
Operational	Guest Shack	Front Reception Desk	Patrol Property	Contact Authorities	Multitask Security Staff	
Physical	Door Lock	Warning Signs	Motion Detectors	Fire Extinguisher	Power Generator	

Directive:

- Direct a subject towards security compliance
- A relatively weak security control

Do this Please:

- Store all sensitive files in a protected folder
- Create Compliance Policies + Procedures
- Train Users on Proper Security Policy
- Post sign for 'Authorized Personnel Only...'

Control Type Examples:

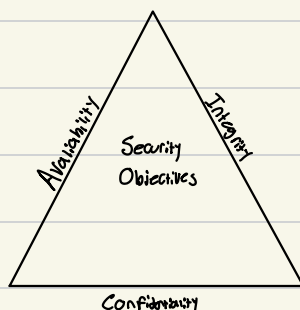
	Preventive	Deterrent	Detective	Corrective	Compensating	Directive
Technical	Firewall	Splash Screen	System Logs	Backup Recovery	Block instead of Patch	File Storage Policies
Managerial	On-boarding Policy	Demotion	Review Login Reports	Policies for reporting issues	Separation of duties	Compliance Policies
Operational	Guard Shack	Reception Desk	Property Patrols	Contract Auditing	Require Multiple Security Staff	Security Policy training
Physical	Door Lock	Warning signs	Motion Detectors	Fire Extinguisher	Power Generator	Sign: Authorized Personnel ONLY

The CIA Triad - 1.2

- Represents the Fundamentals of Security
- Occasionally referred to as the AIC Triad

C: Confidentiality

- Prevent disclosure of information to Unauthorized individuals or systems



I: Integrity

- Messages can't be modified without detection

A: Availability

- Systems are up and running

Confidentiality:

- Certain Information Should Only be Known to Certain People
- Prevent Unauthorized Information disclosure
- Encryption allows for encoding so only particular people can read it
- Access Controls: Selectively restrict Access to a Resource
- TFA (Two-Factor-Authentication): Additional Confirmation before Information is disclosed

Integrity:

- Data is stored and transferred as intended, any Modification would be identified
- Hashing: Map data of an arbitrary length to data of a fixed length
- Digital Signatures: Mathematical Scheme to Verify the integrity of data
- Certificates: Combine with a digital Signature to Verify an individual
- Non-Repudiation: Provides Proof of integrity, can be asserted to be genuine.

Availability:

- Information is accessible to authorized Users at all times
- Redundancy: Build Services that will Always be available
- Patching: Stability, Close Security holes

Non-repudiation 1.2:

- You cannot deny what you've signed, e.g. no taking it back
- Sign a contract, your signature adds non-repudiation, you really did sign the contract, others can see your signature
- Adds a different perspective for cryptography.
- Proof of integrity
- Proof of origin, with high assurance of authenticity

Proof of integrity:

- Verify data does not change
- The data remains accurate & consistent
- In cryptography, we use a hash
- Represent data as a short string of text
- A message digest, a fingerprint.
- Gutenberg Encyclopedia*
- Hashing very good at noticing change (use diff to compare)

Proof of origin:

Verifying the person (sender) of the message

- Cryptography uses digital signature, signed with private key, confirmed with public key.
- Hashes can be compared to verify integrity, and proof of origin.

Authentication, Authorization, and Accounting: 1.2

AAA Framework:

Identification

- Who You claim to be / Username

Authentication:

- Prove You are Who You Say

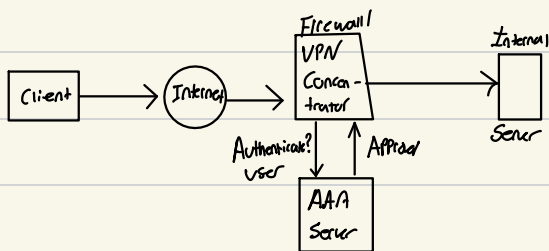
- Password / Other Methods

Authorization:

- Based On Your identification and authentication, What Access do you have?

Accounting:

- Resources Used: Login Time, data sent + received, logout time.

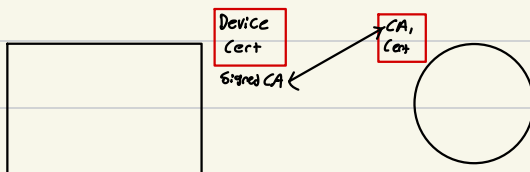


Authenticating Systems:

- Many devices have to be managed
- Often devices you will never see
- A system cannot type a password
- You also may not want to store one
- So how can you truly authenticate a device?
 - Digitally Signed Certificate associated/owned by/with a company.
- Business Processes rely on the certificate
- Management Software can validate the end device

Certificate Authenticator:

- An organization ALWAYS has a trusted
- ↳ Certificate Authority (CA)
- The organization creates a certificate for the device, and signs it with the organization's CA
- The certificate can now be included on a device as an authenticator factor
- The CA's digital signature is used to validate the certificate

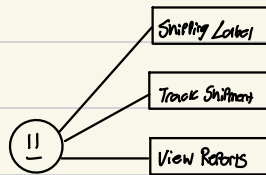


Authorization Models:

- The User/Device has now been authenticated
- To what do they have access?
- Time to apply an authorization Model
- Users and Services $\rightarrow$ data + Applications
- Associating individual users to access rights does NOT Scale.

Simple No Authorization Model:

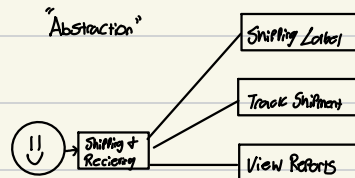
- Simple Relationship: User $\rightarrow$ Resource
- Some issues exist,
- Difficult to understand why authorization may exist
- Does NOT Scale



How can this be improved?

Using an Authorization Model:

- Add an Abstraction
- Reduces complexity
- Creates a clear relationship between the user & resource



Administration is streamlined

- Easy to understand authorization
- Support any number of users or resources

Gap Analysis: 1.2

What is it?: Where you are versus where you WANT to be.

- It is simply the 'gap' between the two

May require extensive research

- A LOT To consider

Can take weeks, or months +

- An extensive study with numerous participants

- Emails, data gathering, Analysis...

Choosing the Framework:

- Work towards a baseline

- This may be an internal set of goals

- May also be formal standards

- Determine the end goal

- NIST Special Publication 800-71 Revision 2, Protecting Controlled Unclassified Information in Nonfederal Systems & Organizations

- ISA/IEC 27001, Information Security management systems

Evaluate People and Processes:

- Get a baseline of employees
 - Formal Experience
 - Current training Knowledge of Security Policies + Procedures
- Examine the current Processes
 - Research existing IT Systems
- Evaluate existing Security Policies.

Compare + Contrast:

The Comparison

- Evaluate existing Systems

Identify Weaknesses

- Along with the most effective processes

A detailed Analysis

- Examine broad Security Categories
- Break these into smaller Segments

Analysis + Report:

- | | | |
|--------------------------------|---|---|
| • The final Comparison | • Need a Path to get from current Security to goal: | • Time to create the gap Analysis report |
| • Detailed baseline objectives | • Will almost certainly involve time, money, and lots of change control | • A formal description of the current state |
| • Clear view of current state | | • Recommendations for meeting the baseline |

Zero Trust 1.2

Many networks are relatively open on the inside

- Once you're through the firewall, there are a few security questions.

Zero trust is a holistic approach to network security.

- Covers every device, every process, every person.

EVERYTHING must be verified:

- Nothing is inherently trusted
- Multi-Factor Authentication, Encryption, System Permissions, Additional firewalls, Monitoring and analytics, etc.

Planes of Operation:

- Split the network into functional planes
- Applies to physical, virtual, and cloud components.

Data Plane

- Processes the frames, packets, and network data
- Processing, forwarding, trunking, encrypting, NAT (Network Address Translation)

Control Plane

- Manages the actions of the data plane
- Defines policies + rules
- Determines how packets should be forwarded
- Routing Tables, Session Tables, NAT tables

Extend the Physical Architecture:

- Separate into functional tasks
- Incorporate into hardware or software e.g. (Data Plane, Control Plane)

Controlling Trust:

Adaptive Identity:

- Consider the source and the requested resources
- Multiple risk indicators - relationship to the organization, physical location, type of connection, IP address. Make the auth stronger, if needed.

Threat Score Reduction:

- Decrease the number of possible entry points

Policy Driven Access control:

- Combine the adaptive identity with a predefined set of rules.

Security Zones:

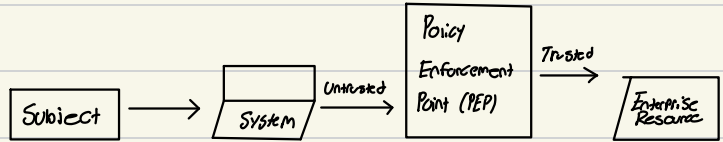
- Security is more than a one to one relationship (User $\rightarrow$ Network)
- Using the zones may be enough itself to deny access
- Broad characterizations provide a security related foundation
- For example, Untrusted or Trusted zone traffic

Where are You coming from and Where are You going?

- Trusted / Untrusted
- Some zones are implicitly trusted
- Internal / External Network
- For example, Trust to Internal zone traffic.
- VPN 1, VPN 5, VPN 11
- Marketing, IT, Accounting, HR

Policy Enforcement Point:

- Subjects & Systems
- End Users, Applications, non-human entities



Policy Enforcement Point (PEP)

- The "Gatekeeper"

Allow, monitor & terminate connections

- Can consist of multiple connection points working together.

Applying trust in the Planes:

Policy Decision Point:

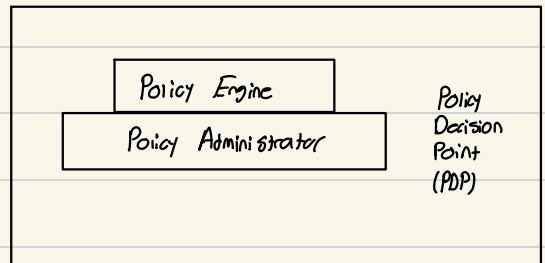
- There's a process for Making an authentication decision

Policy Engine:

- Evaluates each access decision based on a Policy and other information cues
- Grant, deny, or Revoke

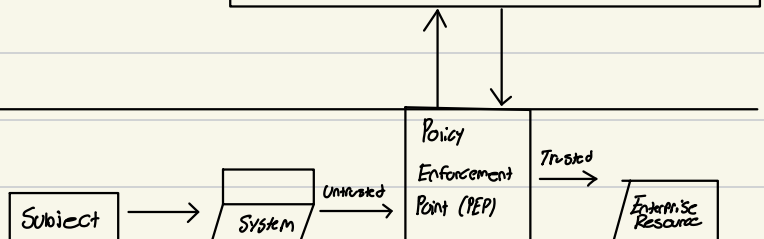
Policy Administrator:

- Communicates with the Policy Enforcement PEP
- Generates Access tokens or credentials
- Tells PEP to allow or disallow Access



Control Plane ↑

Data Plane ↓



Physical Security 1.2

Barriers / Ballots:

- Prevent Access
 - Limits to the Prevention
- Channel People out through a specific access point
- Keep out other things
- Allow People, Prevent cars + trucks

Identify Safety Concerns

- And Prevent injuries

Can be used to an extreme

- Concrete barriers / ballots
- Mounts

Access Control Vestibules:

- All doors normally Unlocked
 - Opening one door usually causes another to lock
- All doors normally locked
 - Unlocking one door prevents others from being unlocked
- One door open / other locked
 - When one door is open the other cannot be unlocked
- One at a time, Controlled groups
- Managed Control through an area

Fencing

- Build a Perimeter
- Typically Very Obvious
- May not be what you're looking for
- Transparent OR opaque
- Robust, difficult to cut
- Prevent Climbing with height or Razor wire.

Video Surveillance:

- CCTV (Closed Circuit Television)
- Can replace Physical Guards
- Camera features are important
- Motion recognition can alarm and alert when something moves
- Object detection can identify a person's face or license plate
- Often MANY different cameras
- Networked together and recorded over time

Guards/Access Badges:

- | | |
|---|--------------------------------|
| • Security guard (Physical Protection) | • Access Badge |
| • Two Person integrity Control | • Picture, name, other details |
| • Minimizes exposure to an attack | • Must be worn at all times |
| • No single person has access to a physical asset | • Electronically Logged. |

Lighting:

- More light Means More Security
- Attackers avoid the light
- Easier to see when lit
- Non IR cameras can see better

Specialized Design:

- Consider Overall light levels
- Lighting angles are important for facial recognition
- Audit Shadows / glare

Sensors:

Infrared:

- Detects infrared radiation in both light and dark
- Common in motion detectors

Pressure:

- Detects change in force
- Floor and window sensors

Microwave:

- Detects movement over larger area

Ultrasonic

- Sends ultrasonic signals, reflected as sound waves.

Deception and Disruption 1.2

HoneyPots:

- Attract the bad guys and trap them
- The "attacker" is probably a machine
- HoneyPots Create a Virtual World to expose a FARE world
- Many different offers
 - Most are often source and available to download

Constant battle to discern real from fake

Honeymats:

- A real network contains more than a single device
- Servers, Workstations, Routers, Switches, Firewalls
- Honeymats
 - Build a larger, more elaborate form of deception

Honeyfiles:

- Attract the attackers with more honey
- Creates files with fake information

Honeyfiles built for the honeynet. (passwords.txt)

- An alert is sent if the file is accessed, like a trap

Honeytoken:

- Track the malicious actors
- Add traceable data to the honeynet

API Credentials:

- Does not actually require access
- Notifications sent when used

Fake Email Addresses:

- Add it to a contact list
- Monitor the internet to see who posts it

Change Management 1.3:

How to Make a Change

- Upgrade Software, Patch an application, Change Firewall Configuration, Modify Switch Ports.

One of the most common issues in the enterprise

- Occurs very frequently

Often overlooked or ignored

Have clear policies:

- Frequency, duration, installation Processes, Rollback Procedures

Sometimes very difficult to implement

- Hard to change corporate culture

Change approval Process:

- A formal process for Managing Change

- Avoid downtime, confusion, and mistakes.

- A typical approval process:

- Complete the request form

- Determine the purpose of the change

- Identify the scope of this change

- Schedule a dated time of the change

- Determine affected systems and the impact

- Analyze the risk associated with the change.

- Get approval/dissapproval from change board.

Ownership:

- An individual or entity need to make a change
- They Do NOT Own the Process
- They don't usually Perform the actual Change

The owner Manages the Process

- Process Updates are Provided to the Owner
- Ensures the Process is followed + Acceptable

Suppose Address label Printers need to be updated

- Shipping & Receiving department owns the Process
- IT handles actual change.

Stakeholders:

- Who is impacted by this change?
- They'll want to have input on the Change Management Process

This may not be as obvious as you think

- A single character can include one individual or the entire company

Upgrade software for shipping labels

- Shipping / Receiving
- Accounting Reports
- Product delivery timelines
- Revenue Recognition - CEO visibility

Impact Analysis:

- ie. high, medium, low

The risks can be minor or far reaching

- The fix breaks something else

- OS failures

- Data Corruption

What is the Risk of *NOT* Making the Change?

- Security Vulnerability

- Application Unavailability/Downing

Test Results:

- Sandbox Testing environment

- No Connection to the real world or Production System

Use before Making a Change to Production

- Try the Upgrade, apply the Patch

- Test and Confirm before deployment

Confirm the backout Plan.

- Move everything back to the original

- A Sandbox is not all encompassing

Backout Plan:

The change may ALWAYS fail

- You should always be able to revert changes
- Prepare for worst, hope for best
- Always use backups.

Maintenance Window:

- When is the change happening?
- Perhaps the most difficult process
- During the workday is a poor option
- Overnights are the best choice
- Very hard for 24-hour production schedules

Standard-Operating-Procedure:

- Change Management is critical, Affects everybody
- The process must be well documented.
- Should be available on Intranet.
- Living document

Technical Change Management: 1.3

- Put the Change into Movement Process into action

- Execute the Plan

No such thing as a "Simple Upgrade"

- Many moving parts, Separate events may be required

Change Management is often concerned with "What" Needs to change.

- The technical team is concerned with how.

Allow list / Deny List:

- Any application can be dangerous

- Vulnerabilities, Trojan horses, Malware

Security Policy can control app execution.

- Allow list / Deny List

Allow List:

Nothing runs UNLESS it is approved

Very Restrictive

Deny List:

- Nothing on this list can be executed

- Anti: Virus / Malware

Restricted Activity:

The scope of change is important

- Defines exactly which components are covered

A change approval isn't permission to make any change

- Change Approval is VERY Specific

The scope may need to be expanded during the change window

- It is impossible to prepare for ALL changes.

The Change Management Process determines the next steps

Downtime:

Services will be Unavailable

- The change process be disruptive
- Usually scheduled during non-productive hours

If possible, prevent any downtime

- Switch to secondary system, upgrade the primary, then switch back

Minimize Downtime Events

- Should be automated as much as possible
- Switch back to secondary if issues arise
- Should be part of the backout plan
- Send emails and calendar updates

Restarts:

- Very common..to require a restart
- Reboot the OS, power cycle the switch, bounce the service
- Can the system recover from a power outage?

Services:

- Stop + Restart the service or daemon, may take seconds or minutes

Applications:

- Close the application completely
- Launch new application instance

Legacy Applications

Some applications were here before you arrived

- Often no longer supported by the developer, rendering you the support team
- Documenting the application can help immensely
- May be quirky

Dependencies:

- To complete A, you MUST complete B
- A service will not start without other active services, or specific library version

Modifying a component may require you changing / restoring other components

Dependencies may occur across systems

- Upload firewall code → Firewall management software

Documentation:

- Can be Challenging to Keep UP With Changes
- Often Required With Change Management Process

Updating Diagrams, Adding Policies/Procedures

- New Procedures, Address Updates

Version Control:

Track Changes to a File or Configuration data over time

- Easily Revert to a Previous Setting

Many Opportunities to Manage Versions

- Router Configurations
- Windows OS Patches
- Application registry entries

Not Always Straightforward

- Some devices and operating systems Provide Version Control Features
- May require additional Management Software.

Public Key Infrastructure: 1.4

(PKI)

Policies, Procedures, Hardware, Software, People

- Digital Certificates: Create, distribute, Manage, Store, Revoke

Huge endeavor, lots of planning

Also refers to the binding of Public keys to people or devices

- The CA (Certificate Authority)

- It's all predicated on trust.

Symmetric Encryption:

- A single shared key

- Encrypt + Decrypt w/ the same key.

- If it gets out you'll need another key.

Secret Key Algorithm

- A shared secret

Doesn't scale very well

- Can be challenging to distribute

Still widely used, very fast to use

- Very less overhead than asymmetric

Asymmetric Encryption:

- Public Key Cryptography

- Two or more mathematically related keys

Private Key (kept secret)

Public Key: Anyone can see it, share it away

The Private Key is the ONLY key that can decrypt data encrypted with the Public Key.

- You cannot derive the Private key from the Public Key

The Key Pair:

- Asymmetric Encryption

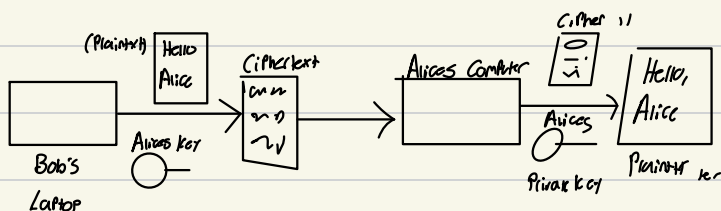
- Public Key Cryptography

- Key Generation

- Build both the Public & Private key at the same time

- Lots of randomization, Large Prime numbers, AND math

- Everybody has the Public Key



Key Escrow:

Someone else holds your decryption keys

- Your Private Keys are in the hands of a third party

Can be a legitimate business arrangement

Very controversial, but sometimes necessary

Encrypting Data: 1.4:

Protect data on Storage devices

- SSD, hard drive, USB drive, cloud storage, etc.
- This is data at rest.

Full disk- and Partition/Volume Encryption

- BitLocker, FileVault, Etc.

File Encryption:

- EFS (Encrypting File System), third party Utilities

Database Encryption:

Protecting Stored data, and transmission of that data

Transparent Encryption

- Encrypt ALL database information with a symmetric key

Record-Level Encryption

- Encrypt individual columns
- Use separate symmetric keys for each column

Transport Encryption:

Protect data traversing the Network (https)

Encrypting the data, e.g. browsers communicate using HTTPS

VPN (Virtual Private Network)

- Encrypts ALL data transmitted over the network, regardless of the application

- Client based VPN using SSL/TLS

- Site to site VPN using IPSec

Encryption Algorithms:

There are many, many different ways to encrypt data.

- The proper "formula" must be used for encryption & decryption

Both sides decide on the algorithm prior to encrypting the data.

- Details often hidden from the end user

- Advantages/Disadvantages between Algorithms

- Security level, Speed, Compatibility, etc...

Cryptographic Keys:

- Very little that isn't known about the cryptographic process

- Algorithm is usually a known entity, only thing not known is the key

- Key determines the output: Encrypted data, Hash Value, digital Signature

Key Lengths:

- Larger keys tend to be more secure
- Prevent brute force attacks
- Attackers can try EVERY possible key combination

Symmetric Encryption

- 128 Bit or larger keys are common
- These numbers get progressively longer as time passes.

Asymmetric Encryption

- Complex calculation of prime numbers
- 3072+ Bits

Key Stretching:

A Weak Key, is just weak, however:

- A weak key could be made stronger by performing multiple processes
- Hash a password, Hash the hash... So on...
- Brute force attacks would then require reversing of each of these hashes

Key Exchange: 1.4

A logistical Challenge:

- How can an encryption key be shared without an insecure network?

Out-Of-Band Exchange:

- Don't send the symmetric key over net

- Telephone, Courier, In-Person, etc.

In-Band Key Exchange:

- It's on the network

- Protect the key with additional encryption

- Use asymmetric encryption to deliver a symmetric key

Real-Time Encryption/Decryption:

There's a need for fast security

- Without compromising the security part

Share a symmetric session key using asymmetric encryption

- Clients encrypt a random (symmetric) key with a server's public key

- This server decrypts this shared key and uses it to encrypt data

- This is a session key

Implement Session Keys carefully

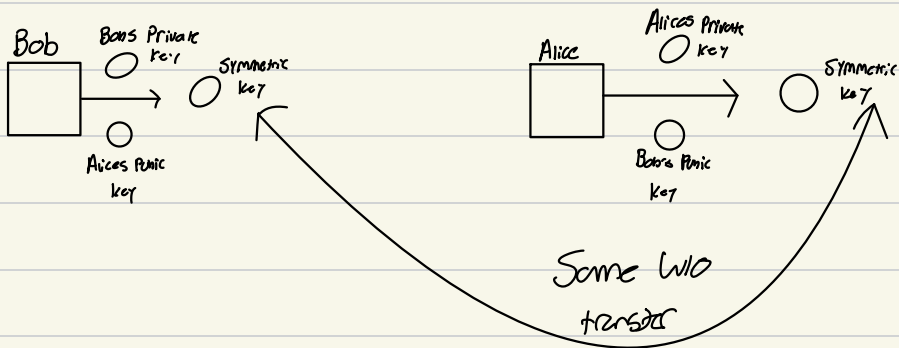
- Needs to change often (ephemeral keys)

- Needs to be unpredictable

Symmetric + Asymmetric keys:

Use Public and Private key cryptography to Create a Symmetric key

• Math is Power



Encryption Technologies: 1.4

Trusted Platform Module (TPM):

- A Specification for cryptographic functions
- Cryptography hardware on a device

Cryptographic Processor:

- RNG, Key Generators

Persistent Memory: Unique keys burned in during manufacturing

Volatile Memory: Storage keys, hardware configuration information

Password Protection, no dictionary attacks

Hardware Security Module (HSM):

Used in large environments

- Clusters, redundant power
- Securely store thousands of cryptographic keys

High end cryptographic hardware

Key Backup: Secure storage in hardware

Cryptographic Accelerators: Offload that CPU overhead from other devices

Key Management System:

Services are Everywhere

- On Premises, cloud based
- Many different keys for many different services

Manage ALL keys from a centralized manager

- Often provided as third-party software
- Separate the full encryption keys from the data

ALL key management from the console

- Create keys for specific service or cloud provider (SSL/TLS/SSH, etc)
- Rotate keys regularly

Keeping data Private:

Our data is located in many different places

- Mobile Phones, cloud, laptop, etc
- The most private data is often physically closest to us

Attackers are always finding new techniques, have to stay one step ahead

Our data is constantly changing, how do we adapt?

Secure Enclave:

- Built in protected area for our secrets, often implemented as hardware processor.
- Has its own boot ROM, has a true RNG, Real time Memory Encryption, AES encryption

Obscuration: 1.4

The Process Of Making Something Unclear / Concealed

Not impossible to Understand. If you know how to Understand it.

Essentially Hiding information in Plain Sight

Hiding information inside of an image

• Steganography

Steganography:

Greek for 'concealed writing'

• Security through Obscurity

Message is invisible, but its really there

The Context: The 'container document or file

Common Steganography Techniques:

Network based: Embedded Messages in TCP Packets

Use on image

Invisible Watermarks: Yellow dots on printers

Other Steganography types:

Audio Steganography: Interlary Secret Message Within the audio

Video Steganography: Large scale image steganography

Tokenization:

- Replace Sensitive data With a Non-Sensitive Placeholder

- SSN 266-12-1112 is now 691-61-8539

Common With Credit Card Processing

- Apple Pay / One time Use Tokens

This is NOT encryption or hashing

- Original token and data are not Mathematically Related

Data Masking:

Data Obscuration

- Hide Majority of data xxxx 1234

Protects PII and other Sensitive data

May not be hidden from View

Many different techniques:

- Substituting, Shuffling, Encrypting, Masking Out, etc...

Hashing + Digital Signatures: 14:

- Represents data as a short string of text
- A Message digest, a fingerprint

One-way trip:

- Impossible to recover the original message from the digest
- Used to store Passwords / Confidentiality

Verify a downloaded document is the same as the original: Integrity

Can be a digital signature

- Authentication, revocation, integrity

Hash Example:

SHA256 Hash

- 256 bits / 64 hexadecimal chars

My Name is Professor Messer:

Hash: a3597916a2...

My Name is Professor Messer!

Hash: 2295181151b2...

Any changes render super different hashes

Collision:

Hash functions:

- Take input of any size
- Create a fixed size string

Message digest, Checksum

The hash should be unique, different inputs should never result in the same hash

- If they do, that is a collision.

MD5 has a collision problem

- Found in 1996

Practical Hashing:

Verify a downloaded file

- Hashes may be provided on the download site
- Compare the download site hash with the posted hash value

Password Storage:

- Instead of storing the password, store a salted hash
- Compare hashes during authentication process
- Nobody ever knows your actual password!

Adding Salt:

Salt: Random data that is added to a Password when hashing

Every user gets their own Random Salt

- Commonly Stored with the Password

Rainbow tables: Reverse engineered hash table to get data

- Will not work on salted hashes

This drastically slows down a brute force attempt

Salting the Hash:

Each user gets a different hash

- The Same Password Creates a different hash

Password	Hash
dragon	a3295...
dragon + 95E2	b7286...
dragon + H2H15	118c192...

Digital Signature:

Uses hashing:

Proves the Message was not changed: Integrity

Proves the Source of the Message: Authentication

Ensures that the Signature is NOT fake: Non Repudiation

Sign in with Private key

Verify the Public Key

Blockchain Technology: 1.4

A distributed ledger

- Keeps track of transactions

Everyone on the blockchain Network maintains the ledger

- Records are replicants to anyone and everyone

Many Practical applications

- Payment Processing
- Digital Identification
- Supply Chain Monitors
- Digital Voting

Used for Cryptocurrency and other digital currencies

Certificates: 1.4

Digital Key:

A Public Key Certificate

- Binds a Public Key and digital Signature
- And other details about key holder

A digital Signature adds trust:

- PKI uses CAs for additional trust
- Web of trust adds other users for additional trust

Certificate Creation can be built in to the OS

- Part of Windows domain services
- Many third party options

What's in a digital Certificate?

- X.509: Standard Format
- Certificate Details
 - Serial Number
 - Version
 - Signature Algorithm
 - Issuer
 - Name of cert holder
 - Public key
 - Extensions

Root of Trust:

Everything associated with IT involves trust

How to build trust from something unknown?

- Someone / Something trustworthy attests this process

Refer to the Root of Trust

- An inherently trusted component
- Hardware, Software, Firmware, or other components
- Hardware Security module (HSM), Secure Enclave, CA, etc

Certificate Authorities:

You connect to a Website: Do you trust it?

Need a good way to trust an unknown entity

- Use a trusted third party, or an authority

CA has digitally signed the Website Certificate

- You trust the CA, therefore you trust the Website

- Real time Verification

Third-Party Authorities:

Built in to your browser

Purchase Your Website Certificate

- Will be trusted by everyone's browser

CA is Responsible for Vetting the request

- They will confirm the certificate owner

Certificate Signing Requests:

- Create a key pair, then send the Public Key to the CA to be signed

- A Certificate Signing Request (CSR)

The CA validates the request

- Confirms DNS emails & website ownership

CA digitally signs the cert, and returns it.

Private Certificate Authorities:

You are your own CA

- Build it in-house

- Your devices must trust the internal CA

Needed for medium to large organizations

Implement as part of your overall computing strategy.

Self Signed Certificates:

Internal Certificates Needn't be signed by Public CA

- Your company is the only one going to use it
- No need to purchase trust for devices that already trust you

Build your own CA:

- Issue your own certificates signed by your own CA

Wildcard Certificates:

Subject Alternative Name (SAN)

- Extensions to X.509 Certificate
- Lists additional identification information
- Allows a certificate to support many different domains

Wildcard domain will apply to ALL Server Names in a domain

Key Rotation:

Certificate Revocation List (CRL)

- Maintained by CA
- Can contain many revocations in a large file

April 2014 - CVE-2014-0160

- Heartbleed
- OpenSSL flaw that the Private Key of affected Web Servers at risk
- Had to be revoked

OCSP Scaling:

Online Certificate Status Protocol

- Provides Scalability for OCSP Checks

The CA is responsible for responding to ALL Client OCSP requests

- May Not Scale Well

Instead, we have CA verify their own status

- Status information is stored on the Certificate Holders Server

OCSP Status is Stuffed into the SSL/TLS handshake

- Digitally Signed by the CA

Getting Revocation details to the browser:

OCSP (Online Cert Status Protocol)

Messages usually sent to an OCSP Responder via HTTP

- Easy to support over internet lines

Not all browsers support OCSP

- Even internet Explorer for example,